

PART 4 OF 18

Enterprise AI Control Architecture

Layered Security Architecture, Policy Enforcement, Trust Zones, Governance Planes, and Production-Grade Reference Design

ENTERPRISE AI CONTROL ARCHITECTURE

Implementation Guide for Production AI Systems • 2026

4.1 Architectural Philosophy: Defense in Semantic Depth

Enterprise AI Control Architecture extends classical defense-in-depth with semantic layers that evaluate the meaning and intent of agent actions, not just their technical attributes. Traditional security layers ask 'Who is making this request?' and 'Are they authorized?'. AI Control layers additionally ask 'What is this agent trying to accomplish?' and 'Is this action consistent with the sanctioned goal?'. This semantic dimension requires new architectural components not present in any prior enterprise security framework.

4.1.1 The Seven Control Planes

- **Identity Plane:** Establishes cryptographic agent identity, manages workload credentials, tracks delegation chains
- **Authorization Plane:** Evaluates access requests against dynamic, goal-aware, context-sensitive policies
- **Capability Plane:** Issues, tracks, and revokes specific functional permissions for individual tasks
- **Execution Plane:** Sandboxes agent execution, enforces resource limits, intercepts actions pre-execution
- **Memory Plane:** Controls read/write access to all memory systems; enforces retention and isolation policies
- **Observability Plane:** Captures reasoning traces, decision telemetry, behavioral metrics, and audit trails
- **Governance Plane:** Enforces organizational policies, manages human approval workflows, maintains compliance

4.2 Layer 1: Identity Plane Architecture

Every agent in the enterprise must have a cryptographically verifiable identity that is distinct from both human identities and traditional service accounts. Agent identity is hierarchical: the platform identity (the agent framework), the agent type identity (the specific agent class), and the instance identity (the running agent session) form a chain of trust.

4.2.1 Agent Identity Components

Identity Component	Purpose	Implementation	TTL
Platform Identity	Identify the agent platform (LangGraph, CrewAI)	X.509 cert signed by enterprise CA	1 year
Agent Type Identity	Identify the specific agent class and version	SPIFFE SVID for agent workload type	90 days
Session Identity	Unique identifier for each agent execution session	JWT with session claims, signed	Session duration
Task Identity	Identity scoped to a single task within a session	Derived JWT with task-specific claims	Task duration

Identity Component	Purpose	Implementation	TTL
Delegation Token	Represent delegated authority from human principal	JWT with delegation chain	Explicit grant period

4.3 Layer 2: Authorization Plane Architecture

The authorization plane is the most architecturally significant component of the AI Control architecture because it must evaluate not just 'can this agent make this API call?' but 'should this agent make this API call given its current goal, context, and action history?'. This requires a policy engine that understands agent semantics.

4.3.1 Policy Decision Architecture

The AI Policy Engine operates as a Policy Decision Point (PDP) that receives enriched authorization requests from the Execution Plane's Policy Enforcement Point (PEP). Enrichment includes: current agent goal, recent action history, current context summary, retrieved memory state, and proposed action with full parameters.

Policy Layer	Evaluates	Policy Language	Decision Speed
Hard Constraints	Absolute prohibitions (never delete production DB)	Cedar / Rego rules	< 1ms
Capability Scope	Is action within issued capability token?	Token claim validation	< 5ms
Contextual Rules	Is action appropriate for current goal and context?	OPA with context enrichment	10-50ms
Behavioral Rules	Does this action match expected patterns for this task type?	ML classifier	50-200ms
Risk Scoring	What is the aggregate risk of executing this action?	Risk model + history	100-500ms
Human Review Gate	Does risk score exceed human review threshold?	Rule-based threshold	Async

Latency Budget: The authorization path must complete hard constraint evaluation in < 5ms to be compatible with high-throughput agent workloads. Contextual and behavioral evaluation can run asynchronously for non-blocking checks, with synchronous blocking only for high-risk action categories.

4.4 Layer 3: Execution Plane Architecture

The execution plane provides the technical enforcement mechanisms that ensure agents can only interact with the environment in ways permitted by the authorization plane. Unlike the policy engine (which makes decisions), the execution plane enforces decisions through technical controls that cannot be bypassed by the

agent.

4.4.1 Execution Sandbox Design

- **Container Isolation:** Each agent task runs in an isolated container with minimal base image; no shared filesystem with other tasks
- **Seccomp Profiles:** System call filtering restricts agent process to minimum required OS capabilities
- **eBPF Monitoring:** Kernel-level behavioral monitoring captures all system calls, network connections, and file operations
- **Network Egress Control:** Egress limited to allow-listed endpoints; DNS resolution restricted; direct IP connections blocked
- **Resource Quotas:** CPU, memory, disk I/O, and network bandwidth limits prevent resource exhaustion attacks
- **Ephemeral Storage:** All file system state is temporary; persistence requires explicit write to governed memory system
- **Capability Drop:** Linux capabilities dropped to minimum (no CAP_NET_RAW, CAP_SYS_ADMIN, etc.)

4.5 Layer 4: Memory Plane Architecture

Agent memory is a first-class governance concern. All agent memory systems must be treated as regulated data stores with access controls, retention policies, integrity verification, and audit trails. Memory is categorized by persistence scope and organizational sensitivity.

Memory Type	Scope	Access Control	Retention	Integrity
Working Memory	Single task	Task identity token	Auto-delete at task end	None required
Session Memory	Single session	Session identity token	Delete at session end + grace period	Integrity hash on write
Agent Episodic Memory	Agent instance lifetime	Agent type identity + human approval	Configurable; default 90 days	Signed at write; verified at read
Shared Org Memory	Cross-agent, organizational	ABAC with data classification	Aligned with data retention policy	Content hash + provenance
Long-term Knowledge	Persistent enterprise knowledge	Read: agent type; Write: human only	Indefinite with review cycle	Merkle tree integrity

4.6 Reference Architecture: Single-Agent Production System

The following describes the reference architecture for a single autonomous agent deployed in a production enterprise environment. This architecture implements all seven control planes and provides the baseline for more complex multi-agent deployments.

4.6.1 Architecture Component Manifest

Component	Function
Agent Gateway	API gateway providing the agent's external interface; enforces TLS, rate limiting, authentication
Identity Broker	Issues session and task identity tokens; validates delegation chains; integrates with enterprise IdP
AI Policy Engine	PDP with hard constraints, contextual rules, behavioral rules, and risk scoring
Action Interceptor	PEP inline in agent execution path; blocks or approves actions based on PDE decisions
Execution Sandbox	Container-based isolated execution environment per task with eBPF monitoring
Capability Broker	Issues JIT capability tokens for specific tool access; validates against active task scope
Memory Governor	Controls all memory reads/writes; enforces access control and integrity verification
Tool Registry	Authoritative registry of approved tools with metadata, trust scores, and version control
Reasoning Telemetry	Captures full reasoning traces, decision points, and plan states for audit
Human Approval Queue	Workflow system for human review of flagged actions; SLA-monitored
Behavioral Analytics	Real-time analysis of action patterns against behavioral baseline
Audit Store	Immutable append-only log of all agent actions, decisions, and their authorization outcomes